

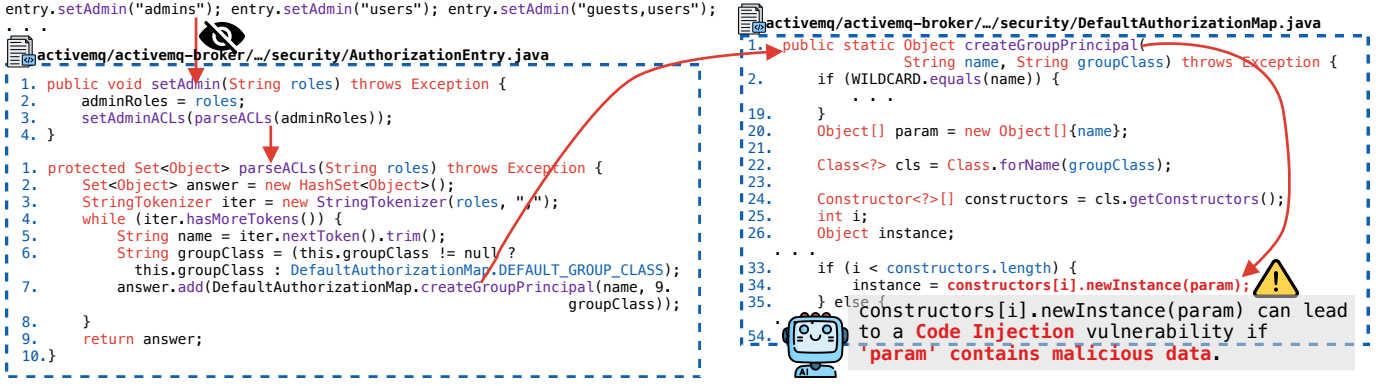


Fig. 12: An illustrating example FP reported by IRIS of reason A1

APPENDIX A CASE STUDY

In RQ3 (Section V-C), we introduced a taxonomy of false-positive (FP) causes detected by the selected methods and showcased two representative examples for categories A2 and B1. In this section, we present the remaining examples of all 9 categories.

1) *Example Program for Reason A1*: Fig. 12 illustrates an FP reported by IRIS in the `apache/activemq` project. IRIS (via the LLM) flags the creation of a new instance with `param` as a potential code-injection risk, assuming that `param` may contain attacker-controlled content. However, tracing the data flow shows that `param` originates from the `roles` argument of `setAdmin`, is propagated through `parseACLs`, and is ultimately passed into `createGroupPrincipal`. Further inspection of all call sites of `setAdmin` in the project indicates that the supplied arguments are hard-coded string literals (e.g., "admins", "users", ...), and therefore cannot contain malicious input. This FP arises because the LLM's analysis considers the data flow starting at `roles` but does not incorporate the concrete invocations of `setAdmin`, leading it to incorrectly treat `param` as untrusted.

2) *Example Program for Reason C1*: Fig. 13 is an FP due to the prompt deviations (reason C1). As shown in the prompt, IRIS explicitly asks the LLM to determine whether the dataflow contains a CWE-022 vulnerability, and provides the corresponding dataflow details. Based on this information, the LLM can infer that the flow starts from reading an attribute value from an XML element and then uses it as a parameter in a database query. The LLM correctly recognizes that this pattern is unrelated to CWE-022 (Path Traversal or Zip Slip). Nevertheless, it still labels the code as vulnerable, despite being explicitly instructed to judge only whether the provided content constitutes a CWE-022 issue.

3) *Example Program for Reason D1*: Fig. 14 illustrates an FP reported by RepoAudit caused by missing a key program point (Reason D1). In this example, `req` may be assigned NULL by `peci_request_alloc`. RepoAudit infers that this `req` is subsequently passed to `peci_request_xfer_retry`, where the null pointer is dereferenced via `req->device`, and therefore reports a potential null pointer dereference (NPD). However, the tool

PROMPT

Analyze the following dataflow path in a Java project and predict whether it contains a Path Traversal or Zip Slip vulnerability (CWE-022).
Source (`getAttributeValue(...): String`):

```

public class XSLTIngestionCrosswalk {
    private static void applyDimField(Context context, Element field, Item item,
boolean createMissingMetadataFields) {
        throws CrosswalkException, SQLException, AuthorizationException {
            String schema = field.getAttributeValue("mdschema");
            String element = field.getAttributeValue("element"); // <---- THIS IS
THE SOURCE
            String qualifier = field.getAttributeValue("qualifier");
            String lang = field.getAttributeValue("lang");
            String authority = field.getAttributeValue("authority");
            String sconf = field.getAttributeValue("confidence");
        }
    }
}

```

Steps:

- Step 1 [`XSLTIngestionCrosswalk.java:applyDimField`]: `.checkMetadata(context, ...)`
- Step 8 [`MetadataFieldDAOImpl.java:find`]: `public MetadataField find(Context context, int metadataFieldId, MetadataSchema metadataSchema, String element,`

Sink (`element`):

```

public class MetadataFieldDAOImpl extends AbstractHibernateDAO<MetadataField>
implements MetadataFieldDAO {
    public MetadataField find(Context context, int metadataFieldId,
MetadataSchema metadataSchema, String element, {
        ...
        "AND mf.qualifier IS NULL");
    }
    query.setParameter("id", metadataFieldId);
    query.setParameter("name", metadataSchema.getName());
    query.setParameter("element", element); // <---- THIS IS THE SINK
    if (qualifier != null) {
        query.setParameter("qualifier", qualifier);
    }
}

```

The source is a method that retrieves an attribute value from an XML element, which can be controlled by an external input if the XML is user-supplied. The sink is a database query parameter that uses this value, potentially leading to SQL injection if not properly sanitized. However, the vulnerability type specified (Path Traversal or Zip Slip) does not match the observed SQL injection risk.

Fig. 13: An illustrating example FP reported by IRIS of reason C1

overlooks a simple but crucial null-check along this path: when `req` is NULL, the function returns `ERR_PTR` at line 12, which prevents the dereference. Notably, all three related functions shown in this figure are located in the same file and involve neither complex nor long contexts, yet RepoAudit still fails due to this reason.

4) *Example Program for Reason D2*: There is an FP case reported by INFERROI due to limited support for Java language features (Reason D2). In this

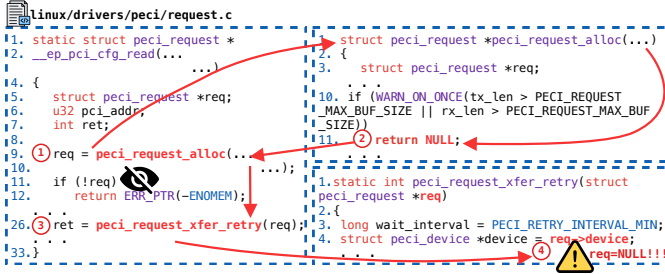


Fig. 14: An illustrating example FP reported by RepoAudit of reason D1

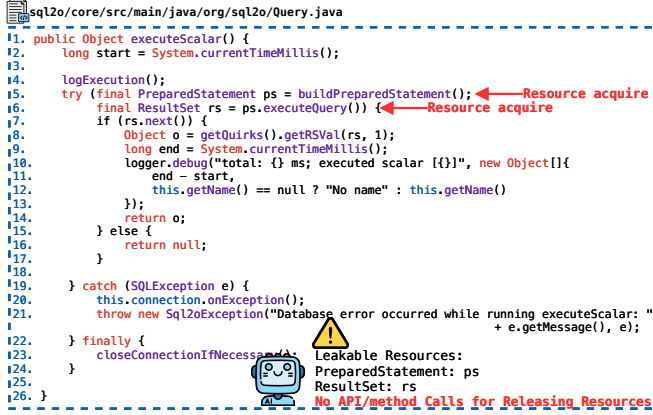


Fig. 15: An illustrating example FP reported by INFERROI of reason D2

example, the LLM correctly identifies two resource-acquisition operations, `buildPreparedStatement()` and `ps.executeQuery()`. However, it overlooks that both are declared in a try-with-resources statement and thinks there are no API/method calls for resource release. When the block exits, the corresponding `PreparedStatement` and `ResultSet` are automatically closed, so no resource leak occurs.

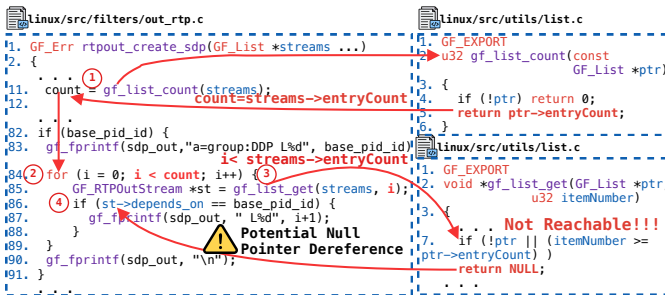


Fig. 16: An illustrating example FP reported by CodeQL of reason D3

5) *Example Program for Reason D3:* Fig. 16 presents an FP reported by CodeQL caused by path-insensitive analysis (Reason D3). As shown, CodeQL thinks that the call to `gf_list_get` may return NULL and assigns it to `st` (Line 85), after which `st` is dereferenced via `st->depends_on` (Line 86). It therefore flags a potential null-pointer dereference (NPD). However, in this context, `count` is initialized with

`streams->entryCount` (Line 11), which ensures that the return NULL; branch in `gf_list_get` is unreachable. Consequently, `st` cannot be NULL at Line 86, and the reported NPD is a false alarm.

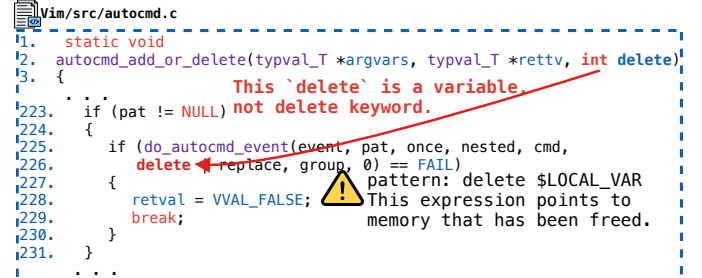


Fig. 17: An illustrating example FP reported by Semgrep of reason D4

6) *Example Program for Reason D4:* There is an FP reported by Semgrep caused by missing type awareness (Reason D4). In this example, Semgrep flags a `delete` operation at Line 226 as if it were freeing allocated memory and then being used in a subsequent function call. However, `delete` here is an integer parameter rather than the C++ memory-deallocation operator, and thus it does not perform any memory-related operation. As a result, the reported issue is a false alarm.

APPENDIX B

CONFIGURATION OF TRADITIONAL STATIC METHODS

To evaluate CodeQL and Semgrep on the two datasets used in this paper, we manually selected from their built-in rule sets those checks that are related to the CWE types under study. Table XIII and Table XIV demonstrate the details rules selected for each CWE type. Although different rules may produce reports with different severity levels (e.g., some are marked as errors and some are only recommendations), we treat them equally in this study.

APPENDIX C

DETAILED OVERHEAD OF SELECTED METHODS

In Section V-D, we report the average overhead of the evaluated methods on the real-world projects. Here, we provide the complete per-project overhead details for each method in Table XVII, XVIII, and Table XIX, XX, XXI.

TABLE XIII: Selected CodeQL rules for each CWE type

CodeQL	CWE-401	Critical/FileMayNotBeClosed.q1, Critical/FileNeverClosed.q1, Critical/MemoryMayNotBeFreed.q1, Critical/MemoryNeverFreed.q1 Critical/NewArrayDeleteMismatch.q1, Critical/DescriptorMayNotBeClosed.q1, CWE-401/MemoryLeakOnFailedCallToRealloc.q1
	CWE-416	Critical/DoubleFree.q1, Critical/UseAfterFree.q1, Critical/ReturnStackAllocatedObject.q1 CWE-416/IteratorToExpiredContainer.q1, CWE-416/UseOfStringAfterLifetimeEnds.q1, CWE-416/UseOfUniquePointerAfterLifetimeEnds.q1
	CWE-476	Critical/InconsistentNullnessTesting.q1, Critical/MissingNullTest.q1, Critical/NotInitialised.q1 CWE-476/DangerousUseOfExceptionBlocks.q1, Critical/GlobalUseBeforeInit.q1
	CWE-022	CWE-022/TaintedPath.q1, CWE-022/ZipSlip.q1
	CWE-078	CWE-078/ExecRelative.q1, CWE-078/ExecTainted.q1, CWE-078/ExecTaintedEnvironment.q1 CWE-078/ExecUnescaped.q1, experimental/CWE-078/ExecTainted.q1, experimental/CWE-078/CommandInjectionRuntimeExec.q1 experimental/CWE-078/CommandInjectionRuntimeExecLocal.q1
	CWE-079	CWE-079/AndroidWebViewAddJavascriptInterface.q1, CWE-079/AndroidWebViewSettingsEnabledJavaScript.q1, CWE-079/XSS.q1
	CWE-094	CWE-094/ArbitraryApkInstallation.q1, CWE-094/GroovyInjection.q1, CWE-094/InsecureBeanValidation.q1, CWE-094/JexlInjection.q1 CWE-094/MvelInjection.q1, CWE-094/SpelInjection.q1, CWE-094/TemplateInjection.q1, experimental/CWE-094/BeanShellInjection.q1 experimental/CWE-094/InsecureDexLoading.q1, experimental/CWE-094/JakartaExpressionInjection.q1 experimental/CWE-094/JShellInjection.q1, experimental/CWE-094/JythonInjection.q1, experimental/CWE-094/SpringViewManipulation.q1 experimental/CWE-094/ScriptInjection.q1, experimental/CWE-094/SpringImplicitViewManipulation.q1
	CWE-722	Resource Leaks/CloseReader.q1, Resource Leaks/CloseSql.q1, Resource Leaks/CloseWriter.q1

TABLE XIV: Selected Semgrep rules for each CWE type

Semgrep	CWE-401	semgrep-rules/c/mismatched-memory-management-cpp.yaml, semgrep-rules/c/mismatched-memory-management.yaml
	CWE-416	r/cpp.lang.security.containers.std-vector-invalidation.std-vector-invalidation r/cpp.lang.security.strings.return-c-str.return-c-str, r/c.lang.security.use-after-free.use-after-free r/cpp.lang.security.strings.string-view-temporary-string.string-view-temporary-string r/cpp.lang.security.use-after-free.local-variable-malloc-free.local-variable-malloc-free r/cpp.lang.security.use-after-free.local-variable-new-delete.local-variable-new-delete r/c.lang.security.function-use-after-free.function-use-after-free
	CWE-476	r/cpp.lang.security.memory.null-deref.null-library-function.null-library-function
	CWE-022	r/java.jax-rs.security.jax-rs-path-traversal.jax-rs-path-traversal, r/java.lang.security.httpServletRequest-path-traversal.httpServletRequest-path-traversal r/java.micronaut.path-traversal.file-access-taint-msg.file-access-taint-msg, r/java.micronaut.path-traversal.file-access-taint-sls.file-access-taint-sls r/java.micronaut.path-traversal.file-access-taint-ws.file-access-taint-ws, r/java.micronaut.path-traversal.file-access-taint.file-access-taint r/java.micronaut.path-traversal.file-taint-msg.file-taint-msg, r/java.micronaut.path-traversal.file-taint-sls.file-taint-sls r/java.micronaut.path-traversal.file-taint-ws.file-taint-ws, r/java.micronaut.path-traversal.file-taint.file-taint r/java.servlets.security.httpServletRequest-path-traversal-deepsemgrep.httpServletRequest-path-traversal-deepsemgrep r/java.servlets.security.httpServletRequest-path-traversal.httpServletRequest-path-traversal r/java.spring.spring-tainted-path-traversal.spring-tainted-path-traversal r/gitlab.find_sec_bugs.FILE_UPLOAD_FILENAME-1, r/gitlab.find_sec_bugs.PATH_TRAVERSAL_IN-1 r/gitlab.find_sec_bugs.PATH_TRAVERSAL_OUT-1.PATH_TRAVERSAL_OUT-1, r/gitlab.find_sec_bugs.PT_ABSOLUTE_PATH_TRAVERSAL-1 r/gitlab.find_sec_bugs.PT_RELATIVE_PATH_TRAVERSAL-1, r/gitlab.find_sec_bugs.WEAK_FILENAMEUTILS-1
	CWE-078	r/java.lang.security.audit.command-injection-formatted-runtime-call.command-injection-formatted-runtime-call r/java.lang.security.audit.command-injection-process-builder.command-injection-process-builder r/java.micronaut.command-injection.tainted-system-command-msg.tainted-system-command-msg r/java.micronaut.command-injection.tainted-system-command-sls.tainted-system-command-sls r/java.micronaut.command-injection.tainted-system-command-ws.tainted-system-command-ws r/java.micronaut.command-injection.tainted-system-command.tainted-system-command r/java.servlets.security.tainted-cmd-from-http-request.tainted-cmd-from-http-request-deepsemgrep r/java.spring.command-injection.tainted-system-command.tainted-system-command r/java.spring.simple-command-injection-direct-input.simple-command-injection-direct-input r/java.lang.security.audit.tainted-cmd-from-http-request.tainted-cmd-from-http-request r/java.spring.security.injection.tainted-system-command.tainted-system-command r/gitlab.find_sec_bugs.COMMAND_INJECTION-1, r/mobsf.mobfsfscan.injection.command_injection.command_injection r/mobsf.mobfsfscan.injection.command_injection_formated.command_injection_warning
	CWE-079	java.lang.security.audit.xss.no-direct-response-writer.no-direct-response-writer java.lang.security.servletresponse-writer-xss.servletresponse-writer-xss, java.micronaut.xss.direct-response-write.direct-response-write java.servlets.security.no-direct-response-writer-deepsemgrep.no-direct-response-writer-deepsemgrep java.servlets.security.no-direct-response-writer.no-direct-response-writer, java.micronaut.xss.direct-response-write.direct-response-write java.servlets.security.servletresponse-writer-xss-deepsemgrep.servletresponse-writer-xss-deepsemgrep java.servlets.security.servletresponse-writer-xss.servletresponse-writer-xss java.spring.tainted-html-string-responsebody.tainted-html-string-responsebody
	CWE-094	r/gitlab.find_sec_bugs.TEMPLATE_INJECTION_PEBBLE-1.TEMPLATE_INJECTION_FREEMARKER-1.TEMPLATE_INJECTION_VELOCITY-1, r/gitlab.find_sec_bugs.SCRIPT_ENGINE_INJECTION-1.SPEL_INJECTION-1.EL_INJECTION-2.SEAM_LOG_INJECTION-1 r/java.lang.security.audit.el-injection.el-injection, r/java.lang.security.audit.ognl-injection.ognl-injection r/java.lang.security.audit.script-engine-injection.script-engine-injection, r/java.spring.security.audit.spel-injection.spel-injection

TABLE XV: Selected Clang Static Analyzer checkers for each CWE type

Clang Static Analyzer	CWE-401	unix.Malloc, unix.MismatchedDeallocator, cplusplus.NewDeleteLeaks
	CWE-416	unix.Malloc, cplusplus.NewDelete
	CWE-476	core.NullDereference, core.NonNullParamChecker, core.CallAndMessage, cplusplus.StringChecker nullability.NullReturnedFromNonnull, unix.cstring.NullArg, unix.StdCLibraryFunctions

TABLE XVI: Selected SpotBugs patterns for each CWE type

SpotBugs	CWE-022	PT_ABSOLUTE_PATH_TRAVERSAL, PT_RELATIVE_PATH_TRAVERSAL, PATH_TRAVERSAL_IN, PATH_TRAVERSAL_OUT
	CWE-078	COMMAND_INJECTION
	CWE-079	XSS_REQUEST_WRAPPER, XSS_SERVLET, JSP_XSS, XSS_REQUEST_PARAMETER_TO_SEND_ERROR XSS_REQUEST_PARAMETER_TO_SERVLET_WRITER, XSS_REQUEST_PARAMETER_TO_JSP_WRITER
	CWE-094	SCRIPT_ENGINE_INJECTION, SPEL_INJECTION, EL_INJECTION, OGNL_INJECTION, GROOVY_SHELL
	CWE-772	OBL_UNSATISFIED_OBLIGATION, OS_OPEN_STREAM, EL_INJECTION, OGNL_INJECTION, GROOVY_SHELL

TABLE XVII: Details of token consumption, analysis runtime for all C/C++ projects (Part I)

CWE Type	Repository Name	Size (KLOC)	Tool	Input tokens (K)	Output tokens (K)	Time (minutes)
CWE-401	linux/sound	1,253.23	RepoAudit [Ⓢ] _{GPT-4}	0	0	9.37
			RepoAudit [Ⓢ] _{GPT-5.4}	0	0	9.75
			KNightter [Ⓢ] _{O3-mini}	61.41	16.48	131.33
			KNightter [Ⓢ] _{GPT-5.4}	191.87	373.73	168.10
			Codex [Ⓢ] _{GPT-5.4}	1,243.23	27.80	11.84
			Claude Code [Ⓢ] _{ClaudeSonnet4.6}	5736.12	16.29	9.58
			CSA	-	-	98.37
			CodeQL	-	-	4.08
			Semgrep	-	-	0.18
	linux/mm	133.95	RepoAudit [Ⓢ] _{GPT-4}	0	0	3.90
			RepoAudit [Ⓢ] _{GPT-5.4}	0	0	2.77
			KNightter [Ⓢ] _{O3-mini}	61.41	16.48	128.53
			KNightter [Ⓢ] _{GPT-5.4}	191.87	373.73	156.19
			Codex [Ⓢ] _{GPT-5.4}	1074.13	45.22	17.17
			Claude Code [Ⓢ] _{ClaudeSonnet4.6}	7574.46	68.94	31.29
			CSA	-	-	123.05
			CodeQL	-	-	0.58
			Semgrep	-	-	0.07
	ImageMagic	680.88	RepoAudit [Ⓢ] _{GPT-4}	0	0	3.32
			RepoAudit [Ⓢ] _{GPT-5.4}	0	0	2.87
			KNightter [Ⓢ] _{O3-mini}	61.41	16.48	37.55
			KNightter [Ⓢ] _{GPT-5.4}	191.87	373.73	41.00
			Codex [Ⓢ] _{GPT-5.4}	2171.69	31.20	16.70
			Claude Code [Ⓢ] _{ClaudeSonnet4.6}	9099.06	66.58	49.54
			CSA	-	-	8.88
			CodeQL	-	-	3.39
			Semgrep	-	-	0.14
CWE-416	linux/net	962.14	RepoAudit [Ⓢ] _{GPT-4}	2735.89	102.44	7.02
			RepoAudit [Ⓢ] _{GPT-5.4}	3,696.52	212.69	23.23
			KNightter [Ⓢ] _{O3-mini}	185.25	47.92	219.84
			KNightter [Ⓢ] _{GPT-5.4}	201.95	54.03	125.25
			Codex [Ⓢ] _{GPT-5.4}	2118.11	30.26	16.52
			Claude Code [Ⓢ] _{ClaudeSonnet4.6}	14539.46	123.91	45.03
			CSA	-	-	91.13
			CodeQL	-	-	2.85
			Semgrep	-	-	0.80
	linux/drivers/net	3,924.62	RepoAudit [Ⓢ] _{GPT-4}	748.51	198.80	21.69
			RepoAudit [Ⓢ] _{GPT-5.4}	344.87	122.59	2.93
			KNightter [Ⓢ] _{O3-mini}	185.25	47.92	221.51
			KNightter [Ⓢ] _{GPT-5.4}	201.95	54.03	87.22
			Codex [Ⓢ] _{GPT-5.4}	2748.73	48.20	22.19
			Claude Code [Ⓢ] _{ClaudeSonnet4.6}	2438.62	23.12	7.70
			CSA	-	-	100.73
			CodeQL	-	-	14.08
			Semgrep	-	-	2.43
	vim	1,192.93	RepoAudit [Ⓢ] _{GPT-4}	24656.59	2916.95	67.18
			RepoAudit [Ⓢ] _{GPT-5.4}	1,973.45	579.30	302.33
			KNightter [Ⓢ] _{O3-mini}	185.25	47.92	123.62
			KNightter [Ⓢ] _{GPT-5.4}	201.95	54.03	36.97
			Codex [Ⓢ] _{GPT-5.4}	3096.39	33.76	16.60
			Claude Code [Ⓢ] _{ClaudeSonnet4.6}	8166.11	127.44	46.12
			CSA	-	-	1.42
			CodeQL	-	-	1.75
			Semgrep	-	-	0.45

TABLE XVIII: Details of token consumption, analysis runtime for all C/C++ projects (Part II)

CWE Type	Repository Name	Size (KLOC)	Tool	Input tokens (K)	Output tokens (K)	Time (minutes)
CWE-476	linux/drivers/peci	1.72	RepoAudit _{GPT-4}	1547.98	211.58	30.65
			RepoAudit _{GPT-5.4}	2,643.78	312.69	43.87
			KNightter _{O3-mini}	127.52	45.26	196.73
			KNightter _{GPT-5.4}	103.31	27.39	232.57
			Codex _{GPT-5.4}	481.64	18.35	13.63
			Claude Code _{ClaudeSonnet4.6}	233.66	3.56	1.94
			CSA	-	-	118.22
			CodeQL	-	-	0.21
			Semgrep	-	-	0.07
	gpac	859.53	RepoAudit _{GPT-4}	38,530.07	3,413.36	132.64
			RepoAudit _{GPT-5.4}	37,612.07	4,387.88	894.63
			KNightter _{O3-mini}	127.52	45.26	132.20
			KNightter _{GPT-5.4}	103.31	27.39	58.64
			Codex _{GPT-5.4}	3231.66	44.69	30.21
			Claude Code _{ClaudeSonnet4.6}	2701.93	32.53	11.03
			CSA	-	-	6.20
			CodeQL	-	-	378.95
			Semgrep	-	-	0.20
	bitlbee	33.65	RepoAudit _{GPT-4}	225,493.97	38,078.26	312.87
			RepoAudit _{GPT-5.4}	143,791.47	13,799.98	487.95
			KNightter _{O3-mini}	127.52	45.26	105.46
			KNightter _{GPT-5.4}	103.31	27.39	35.20
			Codex _{GPT-5.4}	1820.72	24.01	13.01
			Claude Code _{ClaudeSonnet4.6}	14620.30	67.97	20.19
			CSA	-	-	0.25
			CodeQL	-	-	0.37
			Semgrep	-	-	0.10

TABLE XIX: Details of token consumption, analysis runtime for all Java projects (Part I)

CWE Type	Repository Name	Tool	Tool	Input tokens (K)	Output tokens (K)	Time (minutes)
CWE-022	OpenOLAT	1,907.08	IRIS _{GPT-4}	1,752.77	267.13	103.40
			IRIS _{GPT-5.4}	1,011.07	123.128	55.78
			Codex _{GPT-5.4}	5203.01	50.89	26.78
			Claude Code _{ClaudeSonnet4.6}	183.51	14.30	4.72
			SpotBugs	-	-	10.90
			CodeQL	-	-	15.69
			Semgrep	-	-	1.96
	spark	11.94	IRIS _{GPT-4}	8.47	1.45	2.55
			IRIS _{GPT-5.4}	26.83	5.22	4.72
			Codex _{GPT-5.4}	359.25	20.87	7.32
			Claude Code _{ClaudeSonnet4.6}	84.75	18.96	4.09
			SpotBugs	-	-	0.72
			CodeQL	-	-	3.50
			Semgrep	-	-	0.61
	Dspace	448.03	IRIS _{GPT-4}	676.20	95.93	37.03
			IRIS _{GPT-5.4}	405.39	84.43	27.40
			Codex _{GPT-5.4}	1248.66	20.03	8.70
			Claude Code _{ClaudeSonnet4.6}	308.64	22.57	7.59
			SpotBugs	-	-	1.95
			CodeQL	-	-	15.42
			Semgrep	-	-	0.94
	xstream	76.34	IRIS _{GPT-4}	116.92	211.99	10.70
			IRIS _{GPT-5.4}	57.10	16.42	6.12
			LLMDFA _{GPT-4}	18,716.58	778.23	993.00
			LLMDFA _{GPT-5.4}	21,374.79	879.90	647.56
			Codex _{GPT-5.4}	705.84	26.71	10.97
			Claude Code _{ClaudeSonnet4.6}	218.96	12.48	5.19
			SpotBugs	-	-	1.35
			CodeQL	-	-	1.74
			Semgrep	-	-	0.58
	workflow-cps-plugin	238.59	IRIS _{GPT-4}	91.55	20.06	8.02
			IRIS _{GPT-5.4}	107.04	47.79	16.57
			LLMDFA _{GPT-4}	2,748.90	69.50	44.00
			LLMDFA _{GPT-5.4}	3,496.86	52.87	57.58
			Codex _{GPT-5.4}	729.11	13.26	5.22
			Claude Code _{ClaudeSonnet4.6}	337.20	19.47	7.41
			SpotBugs	-	29.14	2.78
			CodeQL	-	-	3.27
			Semgrep	-	-	0.75
	tika	228.31	IRIS _{GPT-4}	468.01	99.10	32.45
			IRIS _{GPT-5.4}	300.49	110.19	24.62
			LLMDFA _{GPT-4}	18,499.28	1,459.38	1654.00
			LLMDFA _{GPT-5.4}	14,123.15	908.77	1093.82
			Codex _{GPT-5.4}	1719.83	29.14	10.99
			Claude Code _{ClaudeSonnet4.6}	72.41	12.13	2.63
			SpotBugs	-	-	1.57
			CodeQL	-	-	9.24
			Semgrep	-	-	0.90

TABLE XX: Details of token consumption, analysis runtime for all Java projects (Part II)

CWE Type	Repository Name	Tool	Tool	Input tokens (K)	Output tokens (K)	Time (minutes)
CWE-079	xwiki-platform	5,553.10	IRIS _{GPT-4}	927.21	188.67	60.48
			IRIS _{GPT-5.4}	236.11	70.03	28.25
			LLMDFA _{GPT-4}	23,864.02	1,994.81	4638.00
			LLMDFA _{GPT-5.4}	28561.13	2600.17	3460.48
			Codex _{GPT-5.4}	2222.14	23.34	11.18
			Claude Code _{ClaudeSonnet4.6}	293.30	26.06	8.10
			SpotBugs	-	-	5.58
			CodeQL	-	-	12.33
			Semgrep	-	-	1.12
	jenkins	300.49	IRIS _{GPT-4}	463.74	79.21	24.32
			IRIS _{GPT-5.4}	357.34	105.46	30.35
			LLMDFA _{GPT-4}	2,535.12	245.51	530.00
			LLMDFA _{GPT-5.4}	2,565.84	209.52	545.36
			Codex _{GPT-5.4}	5999.23	79.99	32.70
			Claude Code _{ClaudeSonnet4.6}	181.56	16.99	6.27
			SpotBugs	-	-	4.93
			CodeQL	-	-	4.64
			Semgrep	-	-	0.38
	keycloak	6,033.86	IRIS _{GPT-4}	921.60	154.35	177.87
			IRIS _{GPT-5.4}	680.38	274.94	89.35
			LLMDFA _{GPT-4}	38,310.33	2,646.89	4141.00
			LLMDFA _{GPT-5.4}	27494.28	2395.05	3219.23
			Codex _{GPT-5.4}	4274.11	37.76	16.14
			Claude Code _{ClaudeSonnet4.6}	233.84	36.02	10.53
			SpotBugs	-	-	3.75
			CodeQL	-	-	14.33
			Semgrep	-	-	0.57
	onedev	552.49	IRIS _{GPT-4}	172.56	36.25	11.32
			IRIS _{GPT-5.4}	84.73	28.79	6.52
			Codex _{GPT-5.4}	1449.46	20.67	8.98
			Claude Code _{ClaudeSonnet4.6}	178.98	19.82	5.06
			SpotBugs	-	-	6.57
			CodeQL	-	-	7.15
			Semgrep	-	-	0.61
	activemq	611.96	IRIS _{GPT-4}	488.44	85.97	2089.47
			IRIS _{GPT-5.4}	442.92	128.26	122.38
			Codex _{GPT-5.4}	981.06	17.71	7.75
			Claude Code _{ClaudeSonnet4.6}	192.08	14.77	4.31
			SpotBugs	-	-	2.55
			CodeQL	-	-	6.78
			Semgrep	-	-	0.39
	cron-utils	16.24	IRIS _{GPT-4}	17.79	3.08	3.67
			IRIS _{GPT-5.4}	19.40	3.17	16.27
			Codex _{GPT-5.4}	649.31	16.79	7.71
			Claude Code _{ClaudeSonnet4.6}	5236.08	59.38	10.70
			SpotBugs	-	-	0.83
			CodeQL	-	-	0.96
			Semgrep	-	-	0.24

TABLE XXI: Details of token consumption, analysis runtime for all Java projects (Part III)

CWE Type	Repository Name	Tool	Tool	Input tokens (K)	Output tokens (K)	Time (minutes)
CWE-722	sql2o	8.03	INFERROI@GPT-4	142.50	64.51	20.25
			INFERROI@GPT-5.4	153.61	82.95	12.57
			Codex@GPT-5.4	670.66	31.56	11.58
			Claude Code*ClaudeSonnet4.6	131.17	24.02	6.27
			SpotBugs	-	-	0.90
			CodeQL	-	-	1.49
	RxJava	325.39	INFERROI@GPT-4	2,871.49	1,408.23	176.27
			INFERROI@GPT-5.4	2,933.26	1,565.81	97.14
			Codex@GPT-5.4	1576.14	33.49	12.90
			Claude Code*ClaudeSonnet4.6	183.96	20.08	5.27
			SpotBugs	-	-	1.28
			CodeQL	-	-	7.23
	jsoup	38.13	INFERROI@GPT-4	566.37	254.78	37.76
			INFERROI@GPT-5.4	603.65	333.42	21.53
			Codex@GPT-5.4	1231.58	51.61	18.36
			Claude Code*ClaudeSonnet4.6	97.30	20.82	5.90
			SpotBugs	-	-	0.95
			CodeQL	-	-	1.04